Analiza i implementacja wielowarstwowego uwierzytelnienia z wykorzystaniem specyfikacji FIDO2

Promotor:
dr. inż. Jacek Majewski

Wykonał:
Adam Szreiber, 121515

Cel pracy

Implementacja wielowarstwowego uwierzytelnienia z wykorzystaniem specyfikacji FIDO 2 oraz analiza działania w serwisie usług poczty elektronicznej.

Badanie przepływu informacji pomiędzy klientem a serwerem z uwzględnieniem wszystkich warstw modelu odniesienia łączonych systemów otwartych.

Ocena efektywności proponowanego rozwiązania w zakresie jego zdolności do przeciwdziałania atakom phishingowym.

Serwis ShildMail

Aplikacja napisana w języku Python z użyciem frameworka Django.

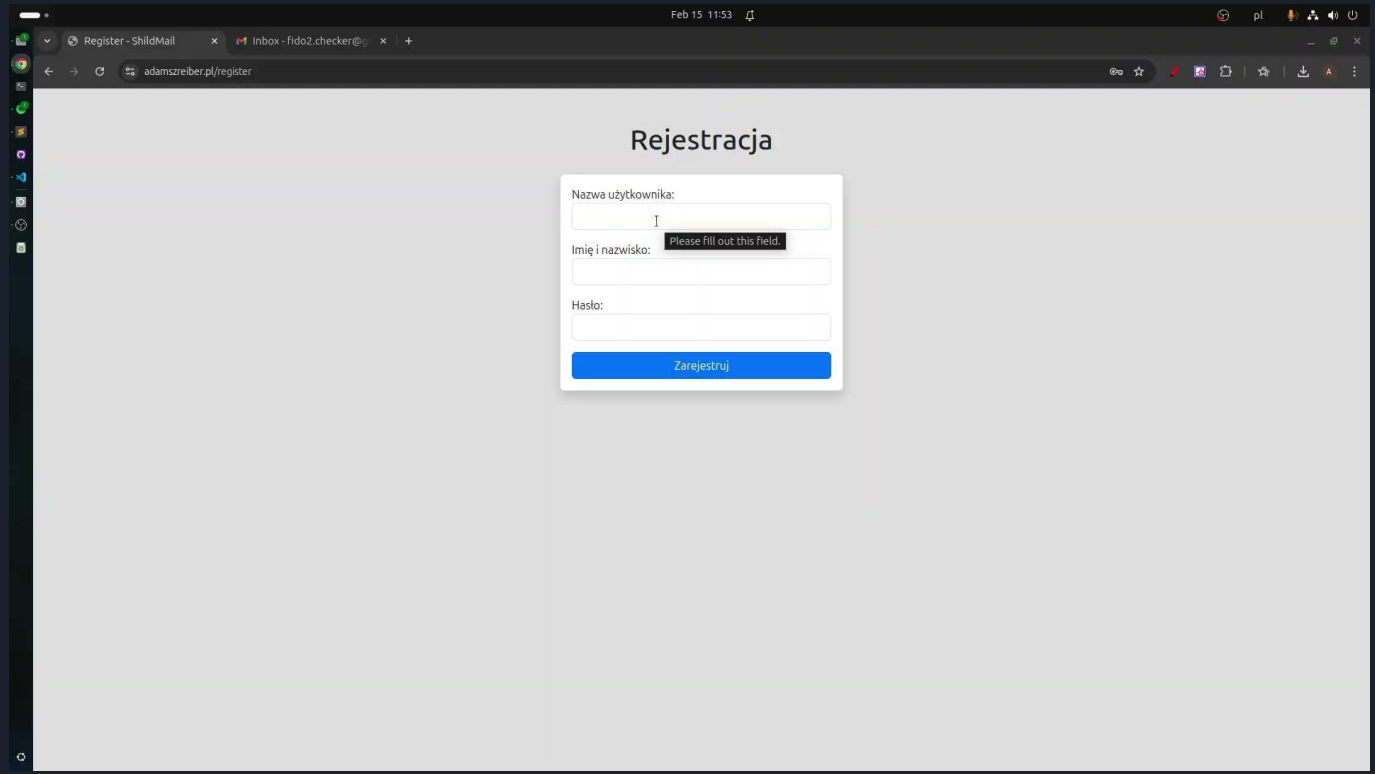
Jest to centralny komponent ekosystemu ShildMail, odpowiedzialny za bezpieczne przetwarzanie wiadomości e-mail. Zapewnia użytkownikowi wygodny interfejs do wysyłania (we współpracy z Postfix) oraz odbierania poczty (przy użyciu Dovecot).

Aplikacja implementuje dwuetapowe uwierzytelnianie, które składa się z tradycyjnego loginu i hasła oraz standardu FIDO2 w roli drugiego składnika potwierdzającego tożsamość użytkownika.

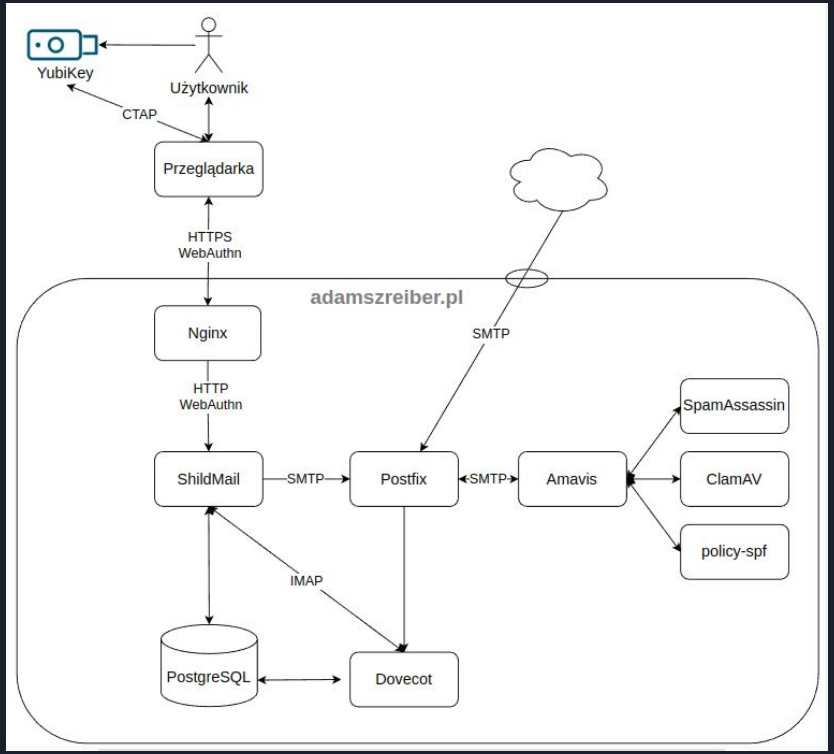
Kluczowe funkcjonalności:

- Rejestracja nowych kont oraz kluczy bezpieczeństwa
- Dwuetapowe uwierzytelnianie
- Zarządzanie pocztą e-mail: odbieranie i wysyłanie wiadomości
- Dodawanie zapasowych kluczy bezpieczeństwa

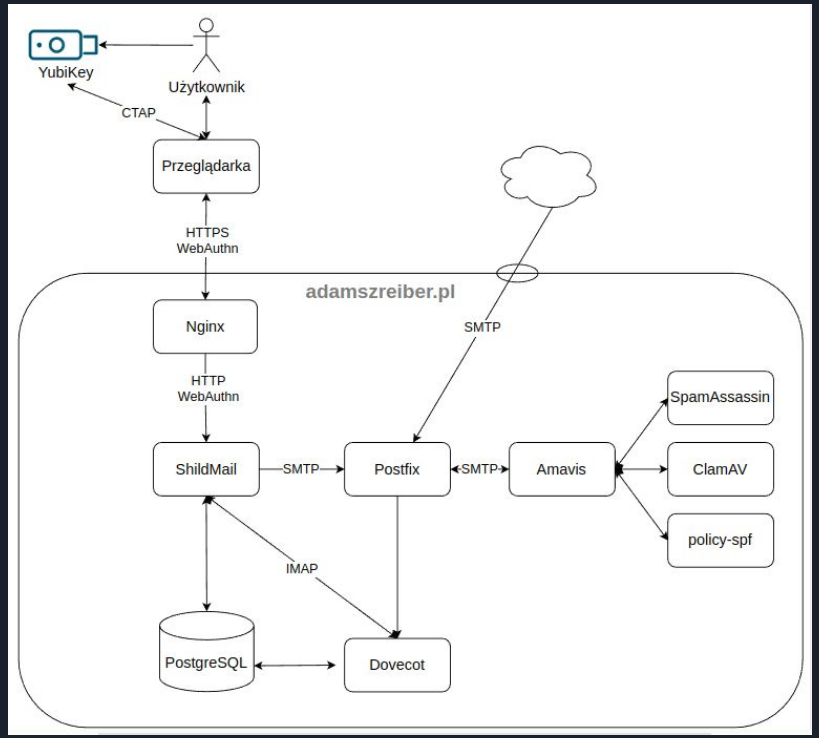
Prezentacja środowiska badawczego



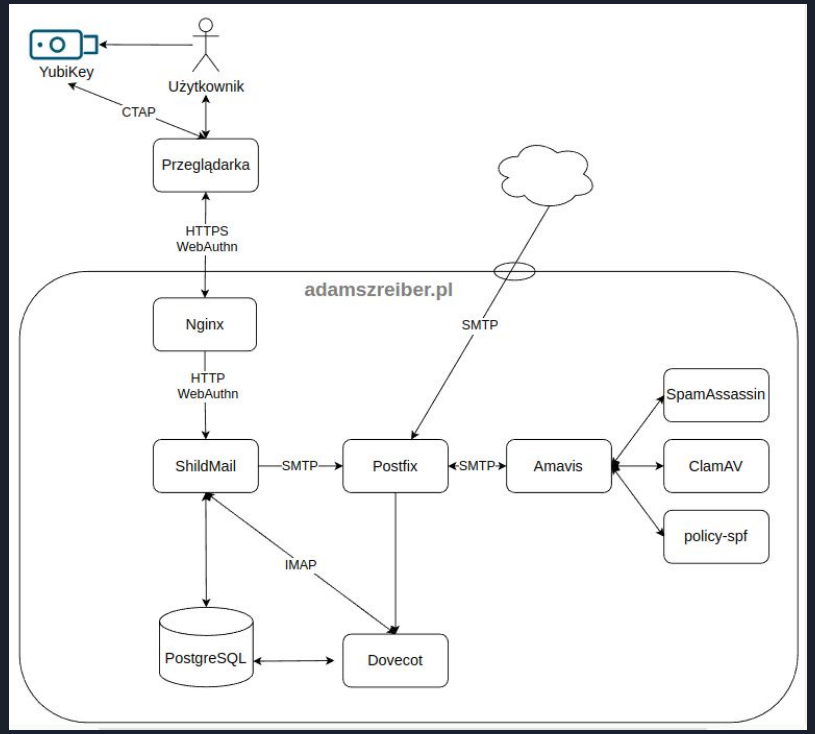
Odebranie nowej wiadomości



Przekazanie wiadomości do skanowania



Skierowanie wiadomości do systemów skanujących



Weryfikacja działania SpamAssassin

Sprawdzenie logów systemowych

Adam Szreiber <mr.honos@gmail.com>
do dave

XJS*C4JDBQADN1.NSBN3*2IDNEN*GTUBE-STANDARD-ANTI-UBE-TEST-EMAIL*C.34X

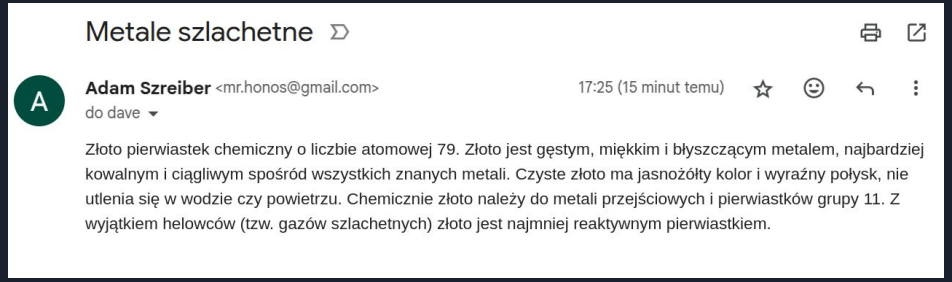
```
2025-02-18T15:33:41.255718+00:00 mail postfix/smtpd[1924167]: connect from mail-yb1-xb31.google.com[2607:f8b0
:4864:20::b31]
2025-02-18T15:33:42.197554+00:00 mail policyd-spf[1924175]: : prepend Received-SPF: Pass (mailfrom) identity=
mailfrom; client-ip=2607:f8b0:4864:20::b31; helo=mail-yb1-xb31.google.com; envelope-from=mr.honos@gmail.com;
receiver=adamszreiber.pl
2025-02-18T15:33:42.261485+00:00 mail postfix/smtpd[1924167]: 3F26949107: client=mail-yb1-xb31.google.com[260
7:f8b0:4864:20::b31]
2025-02-18T15:33:42.315086+00:00 mail postfix/cleanup[1924177]: 3F26949107: message-id=<CAKRCm1d=26o4G80PRLkG
mDV7goGJ-ozHEekJaMEfB2i8YCRHUw@mail.gmail.com>
2025-02-18T15:33:42.317834+00:00 mail postfix/qmgr[1774748]: 3F26949107: from=<mr.honos@gmail.com>, size=3427
, nrcpt=1 (queue active)
2025-02-18T15:33:42.473040+00:00 mail postfix/smtpd[1924167]: disconnect from mail-yb1-xb31.google.com[2607:f
8b0:4864:20::b31] ehlo=2 starttls=1 mail=1 rcpt=1 bdat=1 quit=1 co
2025-02-18T15:33:42.841695+00:00 mail amavis[1590409]: (1590409-04 Blocked SPAM DiscardedInbound,Quarantine
d}, [2607:f8b0:4864:20::b31]:55310 [2607:f8b0:4864:20::b31] <mr.hono> <dave@adamszreiber.pl>, q
uarantine: I/spam-IuUsI_PtHFBq.gz, Queue-ID: 3F26949107, Message-ID: <CAKRCm1d=26o4G80PRLkGmDV7goGJ-ozHEekJaM
EfB2i8YCRHUw@mail.gmail.com>, mail_id: IuUsI_PtHFBq, Hits: 999.803, size: 3426, dkim_sd=20230601:gmail.com, 5
05 ms
```

Weryfikacja skanowania antywirusowego ClamAV



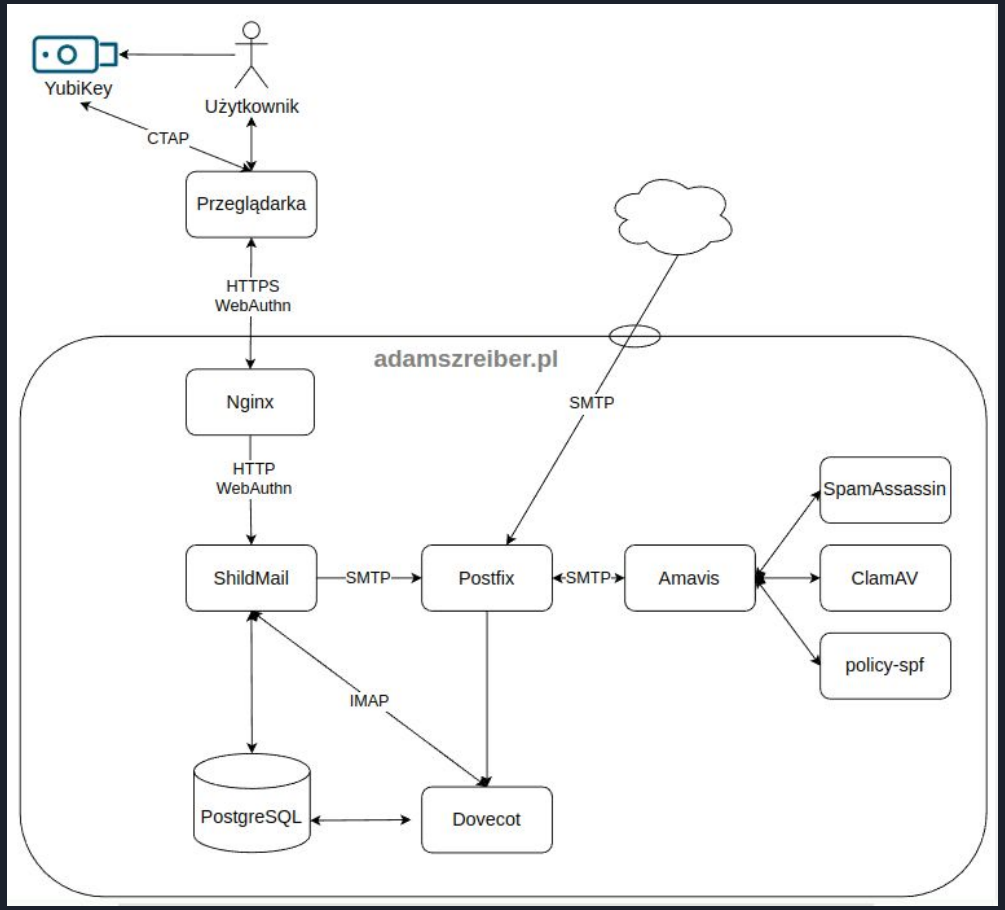

```
2025-02-18T16:13:22.437732+00:00 mail postfix/smtpd[1925722]: connect from mail-yw1-x1136.google.com[2607:f8b0:4
864:20::1136]
2025-02-18T16:13:23.377421+00:00 mail policyd-spf[1925780]: : prepend Received-SPF: Pass (mailfrom) identity=mai
lfrom; client-ip=2607:f8b0:4864:20::1136; helo=mail-yw1-x1136.google.com; envelope-from=mr.honos@gmail.com; rece
iver=adamszreiber.pl
2025-02-18T16:13:23.443425+00:00 mail postfix/smtpd[1925722]: 6C14B49107: client=mail-yw1-x1136.google.com[2607:
f8b0:4864:20::1136]
2025-02-18T16:13:23.474727+00:00 mail postfix/cleanup[1925782]: 6C14B49107: message-id=<CAKRCm1dUB46rcOtGx-hnBVS
wXLe7Mb7shScvxt9aguUrgEPZZQ@mail.gmail.com>
2025-02-18T16:13:23.477887+00:00 mail postfix/qmgr[1774748]: 6C14B49107: from=<mr.honos@gmail.com>, size=3421, n
rcpt=1 (queue active)
2025-02-18T16:13:23.655168+00:00 mail postfix/smtpd[1925722]: disconnect from mail-yw1-x1136.google.com[2607:f8b
0:4864:20::1136] ehlo=2 starttls=1 mail=1 rcpt=1 bdat=1 quit=1 com
2025-02-18T16:13:23.680809+00:00 mail amavis[1590408]: (1590408-04 Blocked INFECTED Eicar-Signature) {Discarde
dInbound,Quarantined}, [2607:f8b0:4864:20::1136]:58747 [2607:f8b0: onos@gmail.com> -> <dave@a
damszreiber.pl>, quarantine: y/virus-yIMxH8Ma26F0, Queue-ID: 6C14B49107, Message-ID: <CAKRCm1dUB46rcOtGx-hnBVSwX
Le7Mb7shScvxt9aguUrgEPZZQ@mail.gmail.com>, mail_id: yIMxH8Ma26F0, Hits: -, size: 3420, dkim_sd=20230601:gmail.co
m, 184 ms
```

Weryfikacja działania polityk SPF




```
2025-02-18T16:25:39.946832+00:00 mail postfix/smtpd[1926108]: connect from unknown[195.211.191.25]
2025-02-18T16:25:39.989985+00:00 mail postfix/smtpd[1926108]: disconnect from unknown[195.211.191.25] ehlo=1 auth=0/1 quit=1 c
ommands=2/3
2025-02-18T16:25:49.529232+00:00 mail postfix/smtpd[1926108]: connect from mail-yw1-x112f.google.com[2607:f8b0:4864:20::112f]
2025-02-18T16:25:50.454468+00:00 mail policyd-spf[1926184]: : prepend Received-SPF: Pass (mailfrom) identity=mailfrom; client-
ip=2607:f8b0:4864:20::112f; helo=mail-yw1-x112f.google.com; envelope-from=mr.honos@gmail.com; receiver=adamszreiber.pl
2025-02-18T16:25:50.521188+00:00 mail postfix/smtpd[1926108]: 7F29349107: client=mail-yw1-x112f.google.com[2607:f8b0:4864:20::
112f]
2025-02-18T16:25:50.563071+00:00 mail postfix/cleanup[1926186]: 7F29349107: message-id=<CAKRCm1cW6=PTEd95SXcMhOLUZKfUNHZB4jRhO
y89uP77GVxVyw@mail.gmail.com>
2025-02-18T16:25:50.566757+00:00 mail postfix/qmgr[1774748]: 7F29349107: from=<mr.honos@gmail.com>, size=4486, nrcpt=1 (queue
active)
2025-02-18T16:25:50.733882+00:00 mail postfix/smtpd[1926108]: disconnect from mail-yw1-x112f.google.com[2607:f8b0:4864:20::112
f] ehlo=2 starttls=1 mail=1 rcpt=1 bdat=1 quit=1 commands=7
```

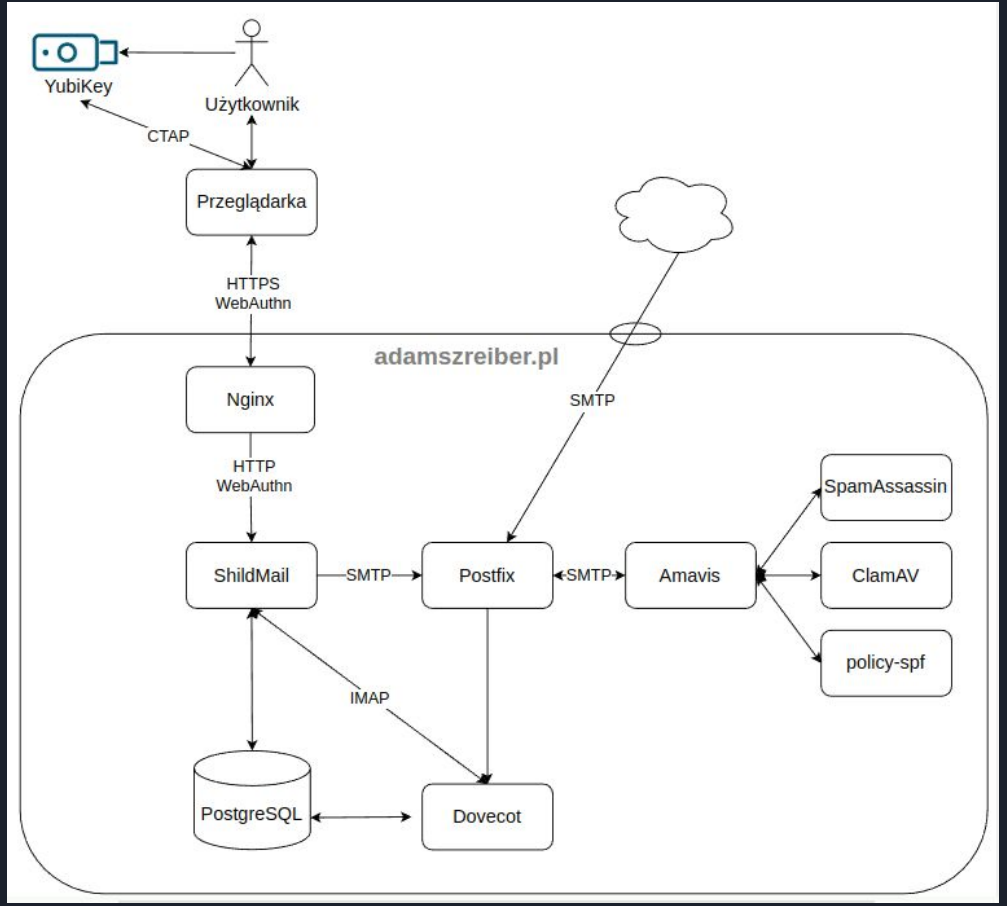
Amavis decyduje o dalszym przetwarzaniu wiadomości



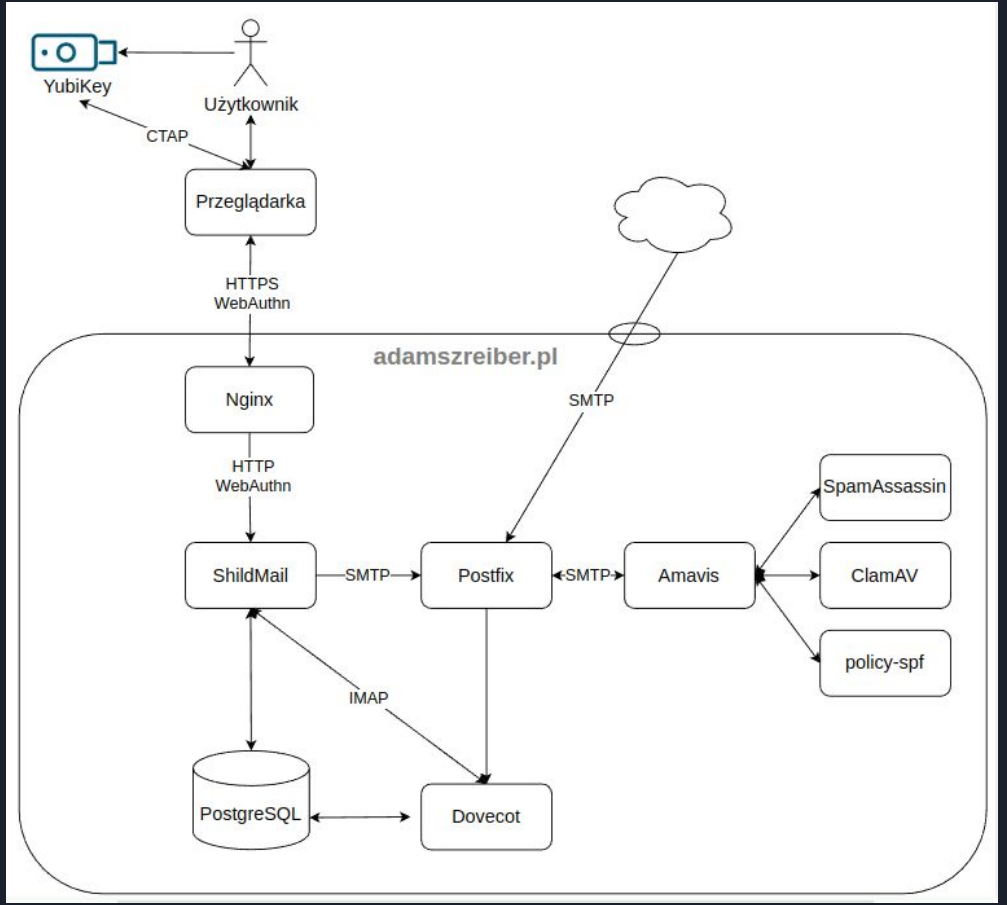
Nagłówki dodane w wyniku skanowania

```
Received: from localhost (localhost [127.0.0.1])
    by mail.adamszreiber.pl (Postfix) with ESMTP id 1EBA149108
    for <dave@adamszreiber.pl>; Tue, 18 Feb 2025 16:25:51 +0000 (UTC)
X-Virus-Scanned: Debian amavis at mail.adamszreiber.pl
Authentication-Results: mail.adamszreiber.pl (amavis);
 dkim=pass (2048-bit key) header.d=gmail.com
Received: from mail.adamszreiber.pl ([127.0.0.1])
 by localhost (mail.adamszreiber.pl [127.0.0.1]) (amavis, port 10024)
 with LMTP id uHZ8PKlSynYm for <dave@adamszreiber.pl>;
 Tue, 18 Feb 2025 16:25:50 +0000 (UTC)
Received-SPF: Pass (mailfrom) identity=mailfrom; client-ip=2607:f8b0:4864:20::112f;
helo=mail-yw1-x112f.google.com; envelope-from=mr.honos@gmail.com;
receiver=adamszreiber.pl
Received: from mail-yw1-x112f.google.com (mail-yw1-x112f.google.com
[IPv6:2607:f8b0:4864:20::112f])
    by mail.adamszreiber.pl (Postfix) with ESMTPS id 7F29349107
    for <dave@adamszreiber.pl>; Tue, 18 Feb 2025 16:25:50 +0000 (UTC)
Received: by mail-yw1-x112f.google.com with SMTP id
00721157ae682-6fb95249855so7835397b3.2
        for <dave@adamszreiber.pl>; Tue, 18 Feb 2025 08:25:50 -0800 (PST)
```

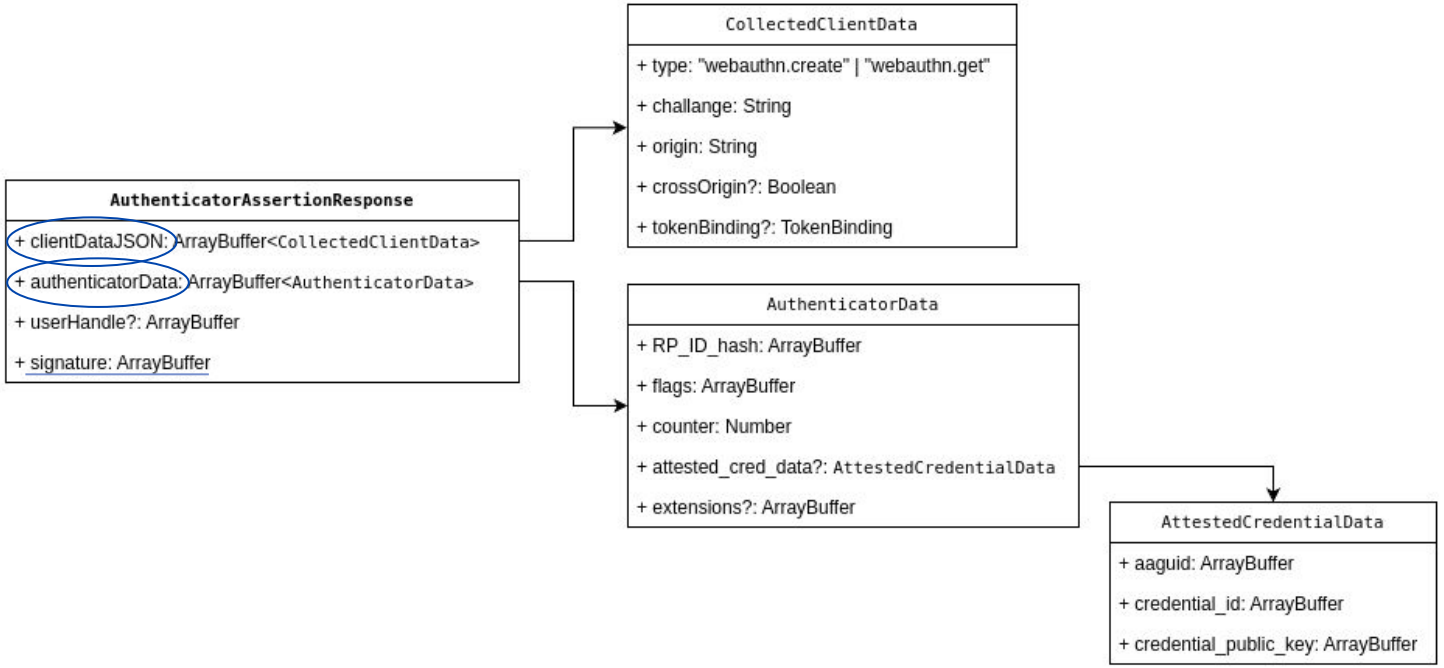
Odesłanie wiadomości do serwera pocztowego odbywa się za pośrednictwem portu “submission”



Dostarczenie mail do skrzynki pocztowej

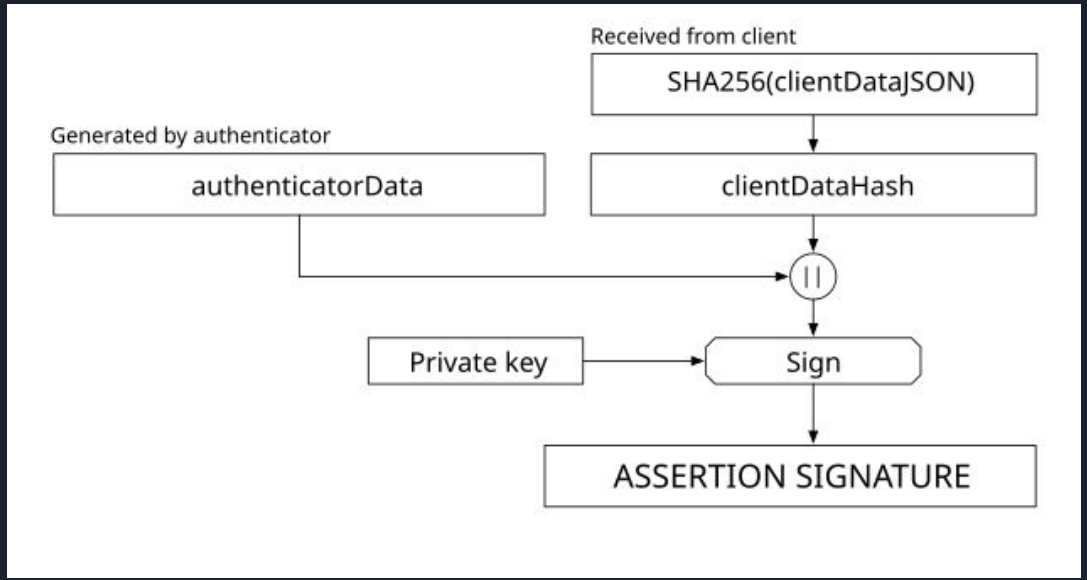


Uwierzytelnianie



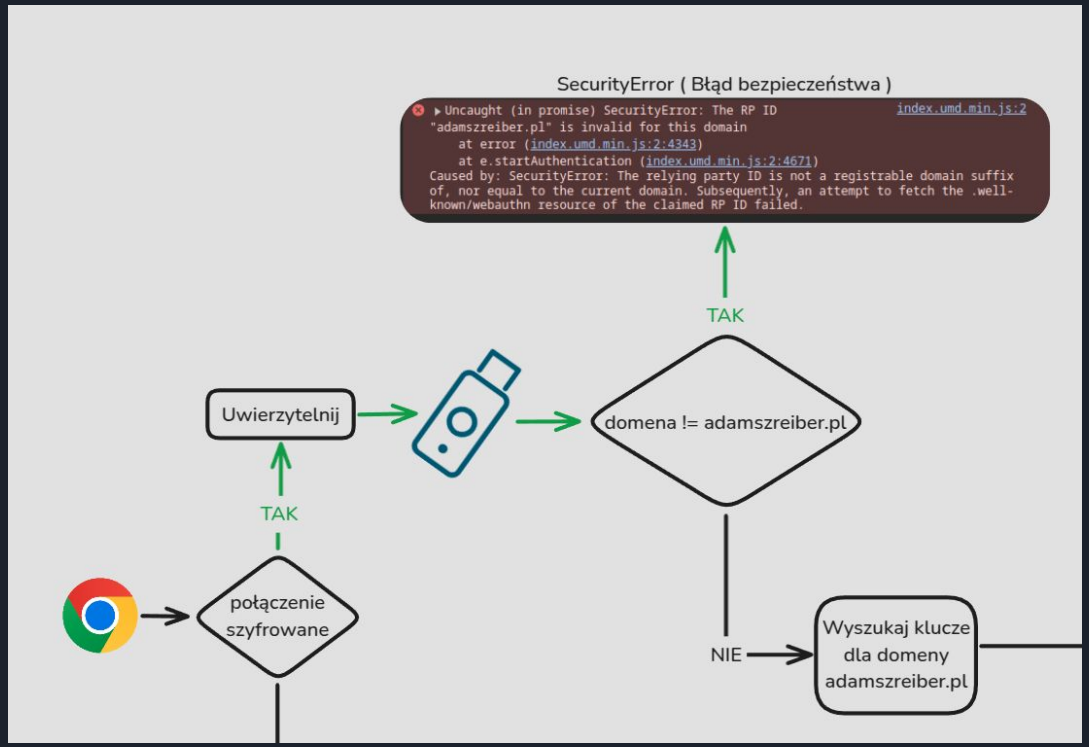
Potwierdzenie pochodzenia danych

Jeżeli podpis zostanie zweryfikowany kluczem publicznym, mamy pewność, że dane pochodzą od właściciela klucza prywatnego.



Ochrona przed phishingiem

Proces logowania na domenie phishingowej.



Ochrona przed atakiem Man in the middle

Podczas rejestracji atakujący dokonał zmiany origin



Ochrona przed Reply Attack

Każde wyzwanie stanowi niepowtarzalny, jednorazowy ciąg znaków

```python
import secrets


def generate_challenge() -> bytes:
    """
    Create a random value for the authenticator to sign, going above and beyond the recommended
    number of random bytes as per https://www.w3.org/TR/webauthn-2/#sctn-cryptographic-challenges:

    "In order to prevent replay attacks, the challenges MUST contain enough entropy to make
    guessing them infeasible. Challenges SHOULD therefore be at least 16 bytes long."
    """
    return secrets.token_bytes(64)
```

Ochrona przed atakami Brute Force

Odgadnięcie klucza prywatnego jest praktycznie niemożliwe



Wnioski końcowe

Zaproponowanie połączenie autentyfikacja opartej na sekrecie wraz z specyfikacją FIDO2 jest komplementarne

TABLE I: Comparison between FIDO2 single-factor authentication using Yubico Security Key and text-based passwords based on the framework by Bonneau et al. [1]

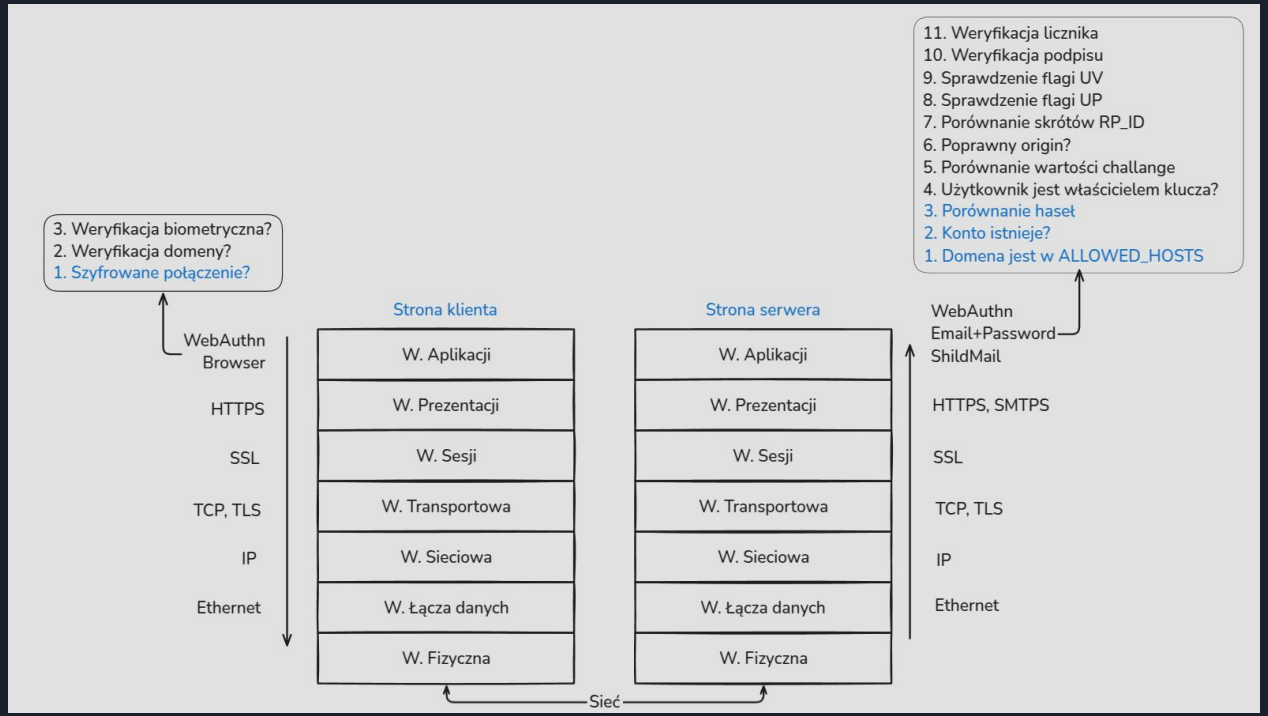
	Usability								Deployability						Security										
Scheme	Memorywise-Effortless	Scalable-for-Users	Nothing-to-Carry	Physically-Effortless	Easy-to-learn	Efficient-to-Use	Infrequent-Errors	Easy-Recovery-from-Loss	Accessible	Negligible-Cost-per-User	Server-Compatible	Browser-Compatible	Mature	Non-Proprietary	Resilient-to-Physical-Observation	Resilient-to-Targeted-Impersonation	Resilient-to-Throttled-Guessing	Resilient-to-Unthrottled-Guessing	Resilient-to-Internal-Observation	Resilient-to-Leaks-from-Other-Verifiers	Resilient-to-Phishing	Resilient-to-Theft	No-trusted-Third-Party	Requiring-Explicit-Consent	Unlinkable
Password	○	○	●	○	●	●	◐	●	●	●	●	●	●	●	○	◐	○	○	○	○	○	●	●	●	●
1FA	●	●	○	●	●	●	●	○	●	◐	○	●	●	●	●	●	●	●	●	●	●	○	●	●	●

● = offers benefit; ◐ = almost offers benefit; ○ = does not offer benefit
■ = depends only on FIDO2 standard and is fixed for all authenticators; otherwise, depends purely or mostly on the authenticator device

[1] J. Lang, A. Czeskis, D. Balfanz, M. Schilder, S. Srinivas “Security Keys: Practical Cryptographic Second Factors for the Modern Web”, 2012

Wnioski końcowe

Specyfikacja FIDO2 rozszerza procesu uwierzytelniania o wiele czynników weryfikacji.



Wnioski końcowe

Zastosowanie klucza biometrycznego wraz z omawianym mechanizmem uwierzytelniania pozwoliłoby **zintegrować wszystkie czynniki uwierzytelniania** („coś, co wiesz”, „coś, co masz” oraz „coś, czym jesteś”).



Dziękuję za uwagę